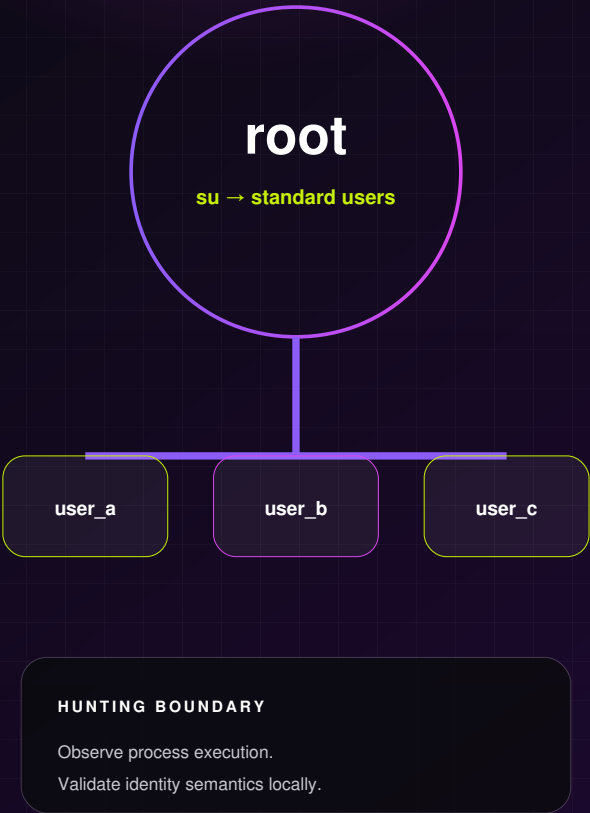


XMRIG ROOT-TO- USER SWITCHING

A Defender XDR hunting model for Linux su execution from root context, based on Group-IB incident-response evidence of pam_rootok abuse.

HUNTING QUERY

CONFIDENCE: MEDIUM



REPORT DATE

31 July 2026

OBSERVED ACTIVITY

May 2026

PRIMARY TELEMETRY

Defender XDR ·
DeviceProcessEvents

OPERATIONAL VALUE

8.3 / 10 · Linux identity
visibility

Hunting query - Untested implementation sketch. A match is an investigation lead, not evidence of malicious PAM use or cryptomining.
INDEPENDENT THREAT RESEARCH · EIGHT-PAGE TECHNICAL DOSSIER



EXECUTIVE ASSESSMENT

Decision-grade summary for SOC and Detection Engineering.

XMRIG · LINUX · 2026

SOURCE FACT

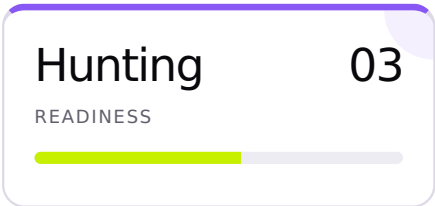
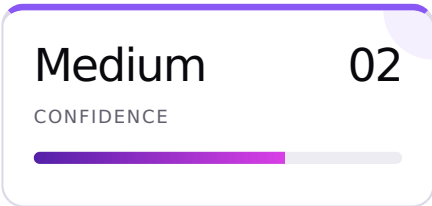
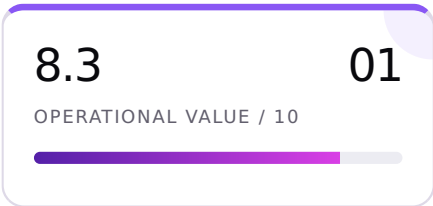
The actor used root access to assume multiple low-privileged identities.

Group-IB observed su used with pam_rootok after privilege escalation. Activity and cron persistence were spread across standard accounts to complicate investigation and recovery.

OPERATIONAL DECISION

Hunt the identity transition; do not alert on it yet.

Root-context su is directly observable in endpoint process telemetry, but legitimate administration overlaps. The first production task is to validate field population and establish approved operational patterns.



CONFIRMED

IR evidence

- Root access preceded the identity switching.
- su and pam_rootok were used.
- Multiple low-privileged users received persistence.

ASSESSMENT

Detection value

- Process execution is durable beyond miner IOCs.
- Results support host and session pivots.
- Local admin patterns can guide tuning.

ASSUMPTIONS

Validation needs

- MDE covers the relevant Linux estate.
- AccountName reflects the su process account.
- Full command line is retained.

Evidence boundary

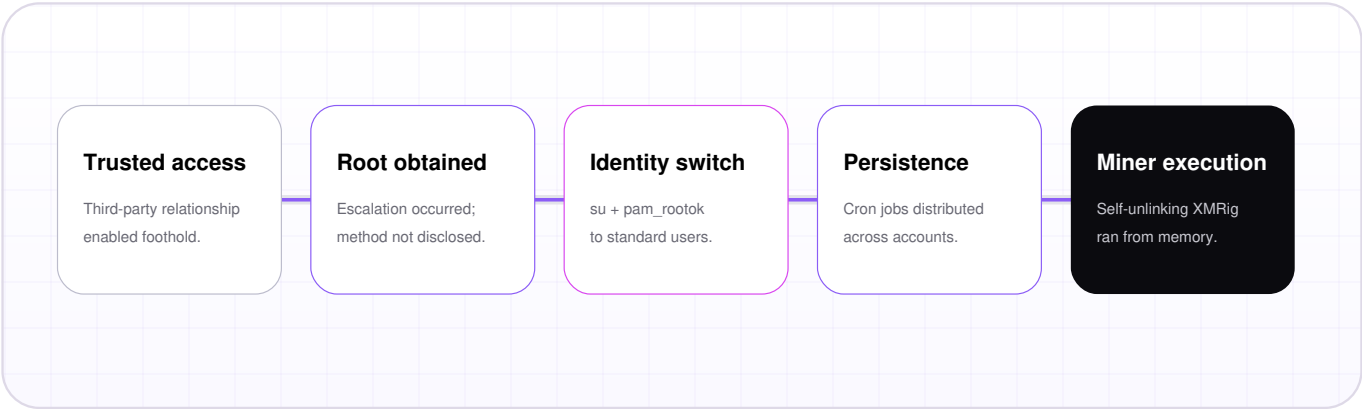
The query does not identify the target account as a structured field and does not prove passwordless switching, pam_rootok, cron persistence, log suppression, self-unlinking, or mining.



BEHAVIOR & ATTACK MECHANICS

Source-supported behavior without extending the chain beyond evidence.

XMRIG · LINUX · 2026



FACT, INTERPRETATION AND OBSERVABILITY

BEHAVIOR	EVIDENCE STATUS	OBSERVABLE SIGNAL	ROLE
Root executes su	Source-confirmed	Process creation, account, command line	Primary anchor
pam_rootok enables switch	Vendor interpretation from IR	PAM/audit logs; not proven by process event alone	Corroboration
Multiple target users	Source-confirmed	Target token in command line; environment-dependent	Scope pivot
Distributed cron persistence	Source-confirmed, commands absent	Crontab/process/file telemetry	Follow-up hunt
Self-unlinking miner	Source-confirmed	Memory/process/file evidence; not covered here	Separate concept

ATT&CK terminology caution

The source associates self-unlinking with T1564.013, while the current ATT&CK catalog defines T1564.013 as Bind Mounts. This dossier does not reproduce that mapping.



TELEMETRY & EVIDENCE MODEL

Minimum data contract and cross-platform implementation boundary.

XMRIG · LINUX · 2026

PRIMARY PLATFORM

Microsoft Defender XDR · DeviceProcessEvents

The documented schema places process name, command line, process account, device, session and event identity in one record. This is the most direct available representation of the selected behavior.

PREREQUISITE

Microsoft Defender for Endpoint on Linux

Run a controlled su test and inspect raw events before relying on account semantics. Missing command line or Linux process events is a hard failure condition.

REQUIRED FIELD CONTRACT

FIELD	RELIABILITY	PURPOSE	FAILURE CONDITION
Timestamp, DeviceId, DeviceName	Documented	Event time and endpoint pivot	Sensor or retention gap
FileName, ProcessCommandLine	Documented; population environment-dependent	Identify su and retain target token	Empty/truncated command line
AccountName	Documented; Linux semantics to validate	Root execution context	Value represents a different identity layer
ProcessId, ProcessCreationTime, LogonId	Documented	Process and session pivots	Incomplete population
ReportId + device + time	Documented	Unique event identity	Key components absent

REQUIRED

Direct evidence

Linux process event with su, root account context and full command line.

OPTIONAL

Enrichment

Linux audit/PAM logs, crontab changes, parent process, CPU use, egress and memory acquisition.

UNAVAILABLE HERE

Outcome proof

PAM policy path, password bypass, target effective identity and miner state.

Secondary platforms

Splunk requires a verified Linux audit/EDR index, sourcetype and field extraction. Chronicle requires an observed parser mapping for process identity and command line. No SPL or YARA-L is published without sample events.

04

HUNTING LOGIC

Primary-platform query and rationale.

XMRIG · LINUX · 2026

DETECTION HYPOTHESIS

If an attacker with root access uses su to distribute malicious activity across low-privileged accounts, process telemetry should show su created under root context with the requested target retained in the command line. Legitimate activity can be distinguished through approved administrator workflows, target-account role, session context and corroborating persistence or log-tampering evidence.

STATUS

Hunting query - Untested implementation sketch

No threshold, window, rarity model, sequence, join, regex or global allowlist is used. The portal time picker defines lookback. Every row remains investigatory.

KQL · HUNTING · UNTESTED

```
// XMRig covert operations: root-initiated Linux user switching
// Platform: Microsoft Defender XDR Advanced Hunting
// Classification: Hunting query - Untested implementation sketch
// Confidence: Medium
//
// Evidence:
// Group-IB observed the actor, after obtaining root, executing `su` to assume
// multiple low-privileged identities without their passwords via pam_rootok.
//
// Detection boundary:
// This query identifies root-context `su` process creation only. It does not
// prove pam_rootok abuse, credential theft, persistence, cryptomining, or
// campaign attribution. Review every result against approved administration.
//
// Prerequisite:
// Microsoft Defender for Endpoint must be deployed on Linux endpoints, and the
// tenant must confirm that DeviceProcessEvents populates AccountName and the
// full ProcessCommandLine for controlled `su` activity.
```

```
DeviceProcessEvents
| where FileName =~ "su"
| where AccountName =~ "root"
| where isnotempty(ProcessCommandLine)
| project
    Timestamp,
    DeviceId,
    DeviceName,
    AccountName,
    FileName,
    ProcessCommandLine,
    ProcessId,
    ProcessCreationTime,
    LogonId,
    InitiatingProcessFileName,
    InitiatingProcessCommandLine,
    ReportId
| order by Timestamp desc
```

REVIEW FIELDS · BASELINE LOCALLY · VALIDATE BEFORE PRODUCTION



TRIAGE & INVESTIGATION

Evidence-led workflow for root-context user switching.

XMRIG · LINUX · 2026

TRIAGE WORKFLOW

- 01

Confirm schema semantics.
Inspect raw event, account, command line and process creation details.
- 02

Identify target identity.
Parse manually from the command line; verify it is a real local or directory account.
- 03

Establish authorization.
Check change records, automation, break-glass and support activity.
- 04

Pivot on session.
Review parent process, shell history, SSH origin, logon ID and adjacent commands.
- 05

Seek corroboration.
Examine cron changes, audit/logging service stops, authentication-log deletion, high CPU, miner egress and memory state.

DISPOSITION

A single su event is not malicious.

- **Benign:** approved workflow, expected target and coherent session context.
- **Suspicious:** unexplained root switch to an unattended or service account.
- **Likely malicious:** repeated identity distribution plus cron, log tampering or miner evidence.
- **Insufficient:** target or account semantics cannot be established.

Process

Parent shell, command line, PID, creation time and adjacent execution.

Session

Logon ID, SSH source, terminal and originating administrator.

Identity

Target account owner, role, normal use and recent activity.

Persistence

User crontab, system cron paths and recently modified scripts.

Visibility

auditd/rsyslog state and authentication-log integrity.

Impact

CPU pressure, Huge Pages/MSR use, mining pools and memory-resident ELF.

Response boundary

Do not isolate a host or disable an account from this match alone. Escalate only after authorization fails or additional persistence, defense-evasion or mining evidence is recovered.



FALSE POSITIVES & VALIDATION

Quality gates before any alerting use.

XMRIG · LINUX · 2026

EXPECTED BENIGN OVERLAP

SCENARIO	LIKELIHOOD	RISK	TUNING ACTION
System administration and troubleshooting	High	High	Bind exclusions to approved operators, hosts and workflows.
Backup, deployment or service-account maintenance	Med	High	Validate exact automation context and expected targets.
Incident response or forensic collection	Low	High	Tag authorized investigation windows; preserve telemetry.
Lab and CI orchestration	Med	Med	Segment lab assets and retain asset-role enrichment.

Validation procedure

- Execute controlled `su - testuser` as root on an onboarded Linux host.
- Confirm `DeviceProcessEvents` values against terminal ground truth.
- Run the hunt over an operationally representative period and classify every result.
- Test pivots to parent process, session and cron/logging telemetry.

DECISION CRITERIA

GATE	REQUIRED OUTCOME
Success	Root context and target command line are accurate and investigable.
Rejection	Account semantics or command line cannot be trusted.
Failure	Coverage is absent or legitimate volume cannot be dispositioned.
Promotion	Measured prevalence, narrow exclusions, runbook and owner exist.

Hunting Current state	Baseline Measure overlap	Candidate Add corroboration	Production Only after precision
---------------------------------	------------------------------------	---------------------------------------	---

Allowlist discipline

Never allowlist all root activity, all `su` execution or entire Linux server groups. Any exclusion must retain an accountable operator, device role, target identity and approved workflow.



ATT&CK, CONCLUSION & REFERENCES

Coverage statement and source control.

XMRIG · LINUX · 2026

MITRE ATT&CK MAPPING

TECHNIQUE	NAME	SUPPORT	COVERAGE STATEMENT
T1078	Valid Accounts	Directly supported by observed account use	The hunt observes identity switching, not initial credential acquisition.
T1562.001	Impair Defenses: Disable or Modify Tools	Source-confirmed logging suppression	Context only; not a query condition.

ANALYST CONCLUSION

A durable and testable hunting boundary, with substantial benign overlap.

Group-IB provides direct incident-response evidence of root-to-standard-user switching through su and pam_rootok. Defender XDR supplies the simplest documented process view. Medium confidence reflects the need to validate Linux field semantics and establish legitimate administrative patterns before any escalation beyond hunting.

REFERENCES

- 1. Group-IB, “XMRig Covert Ops,” published 30 Jul 2026; observed May 2026. <https://www.group-ib.com/blog/xmrig-covert-linux-pam-abuse/>
- 2. Microsoft Learn, “DeviceProcessEvents table in the advanced hunting schema,” accessed 31 Jul 2026. <https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table>
- 3. MITRE ATT&CK T1078 and T1562.001. <https://attack.mitre.org/>

DOCUMENT CONTROL

VERSION	DATE	STATUS	OWNER
v1.0	31 Jul 2026	Hunting · Untested	Detection Engineering

Residual risk

Direct PAM/API activity, incomplete Linux telemetry, truncated command lines and unmonitored accounts can evade this hunt.

Publication control

No customer data, credentials or private identifiers are included. URLs are defanged. The HTML source remains private; only this PDF, the KQL query and references are publishable.